

SQL 注入漏洞报告（Lab7：查询 Oracle 数据库类型和版本）

1. 漏洞名称

SQL Injection（SQL 注入）— 数据库指纹识别与版本信息泄露

2. 漏洞等级

高危（High）

3. 漏洞描述

该网站商品分类查询功能存在 SQL 注入漏洞。攻击者通过 UNION 联合查询，利用数据库特定的内置视图，成功获取了后端数据库的版本信息，暴露了数据库类型及底层环境特征。

4. 漏洞位置

请求方式：GET /filter?category=...

漏洞参数：category

5. 漏洞复现过程

第一步：探测列数与文本列位置

构造 Payload 探测原查询列数及可回显的文本列。由于目标数据库为 Oracle，必须使用 FROM dual 虚拟表完成查询。

Payload:

text

Pets' UNION SELECT 'abc','def' FROM dual—

图 1：探测列数与文本列



说明：页面回显了 abc 和 def，证明原始查询包含 2 列，且两列均为可输出文本的字符列。

第二步：构造版本查询 Payload

已知 Oracle 数据库的版本信息存储在系统视图 v\$version 中。使用 UNION 将查询目标指向该视图。

最终 Payload：

text

Pets' UNION SELECT banner, NULL FROM v\$version—



图 2：获取数据库版本信息

说明：成功读取到系统视图中的 banner 字段，准确识别出目标数据库为 Oracle 11g。



图 3：详细信息展示

说明：攻击者成功获取了 Oracle 服务器的底层架构、操作系统版本及数据库组件的详细信息，为后续利用特定版本漏洞提供了完整情报。

第三步：漏洞原理

原 SQL：

sql

SELECT * FROM products WHERE category='Pets'

拼接后的恶意 SQL：

sql

SELECT * FROM products WHERE category='Pets' UNION SELECT banner, NULL FROM v\$version -- '

- v\$version：Oracle 数据库内置的系统视图，专门用于存储数据库的版本号、核心组件、操作系统类型等信息。
- banner：该视图中的列名，包含了具体的版本字符串。
- 通过该注入，攻击者直接获取了数据库的“指纹”，为后续针对 Oracle 11g 特性的深度攻击（如提权、执行系统命令）提供了依据。

6. 漏洞影响

暴露数据库版本信息等同于暴露了系统的底层架构：

- 攻击者可精准搜索针对该特定版本（Oracle 11g）的已知高危漏洞（CVE）。
- 为后续更深层次的数据库攻击（如提权、读取文件、执行命令）提供关键情报。
- 导致数据库基础安全信息泄露。

7. 修复建议

- ① **使用参数化查询（预编译）**：彻底阻断 SQL 语句拼接，防止注入。
- ② **屏蔽数据库报错信息**：后端发生 SQL 语法错误时，前端统一返回通用错误页面，绝不泄露数据库特有的报错详情。
- ③ **最小数据库权限**：Web 应用连接数据库的账号必须剥夺读取系统视图（如 v\$version）的高权限。

8. 工具

- Google Chrome / Firefox 浏览器（直接修改 URL 参数）
- PortSwigger Web Security Academy（靶场平台）